

112 AI Trainer

Тренажёр диспетчера ДДС

Модель угроз и правила безопасной эксплуатации

Т112 ПД 09

Программная версия v1.0

Разработчик и ответственный за документацию

Кодзаев Николай Петрович

28.09.2026

A handwritten signature in black ink, consisting of stylized, overlapping loops and strokes, likely representing the initials and surname of the developer.

Аннотация

Документ описывает защищаемые данные, границы доверия, возможных нарушителей, сценарии угроз и организационно-технические меры. Предназначен для администратора и ответственного за информационную безопасность.

Содержание

1 Объект защиты и границы	3
2 Активы и границы доверия.....	3
3 Возможные нарушители	4
4 Сценарии угроз и меры	4
5 Настройка доступа.....	5
6 Защита сети и ключей	6
7 Журналирование и резервирование.....	6
8 Действия при инциденте.....	7
9 Уточнение перед вводом.....	7

1 Объект защиты и границы

Объект — локальный учебный комплекс 112 AI Trainer: сервер приложений, БД, модели, АТС, рабочие места и резервные носители. Обработываются учётные данные, учебные карточки, результаты, комментарии, записи голоса и журналы. Реальные экстренные вызовы не подключаются.

Учетная запись, отображаемое имя, оценка и запись голоса могут относиться к данным конкретного обучающегося. Локальное размещение само по себе не отменяет обязанности владельца определить правовое основание обработки, состав данных, сроки хранения и круг доступа. Класс системы, уровень защищённости и обязательные меры определяются владельцем по фактической инфраструктуре.

При внедрении ответственный за ИБ уточняет угрозы и меры защиты для сети организации.

2 Активы и границы доверия

Актив	Требуемое свойство
Пароли, токены, ключи	Конфиденциальность, ограниченный доступ и смена при компрометации
Карточки и оценки	Целостность, привязка к владельцу и версии
Голосовые записи	Конфиденциальность и управляемый срок хранения
Сценарии и эталоны	Защита от несанкционированной публикации и просмотра
Журналы	Доступность для расследования и защита от удаления
Резервные копии	Восстановимость и раздельное хранение ключа
Модели и зависимости	Подлинность источника и контроль версии

Границы доверия проходят между ПК и сервером, Frontend и внутренними API, сервисами и БД, Voice и телефоном, приложением и Ollama, рабочей системой и резервным хранилищем. Модель ИИ не является доверенным источником команд или официальных нормативов.

3 Возможные нарушители

Рассматриваются ученик с обычной учётной записью, посторонний участник локальной сети, пользователь с украденным паролем, ошибающийся преподаватель, администратор с избыточными правами и поставщик скомпрометированного пакета либо файла модели. Также учитываются сбой диска, потеря сети и ошибочное обновление.

Системный администратор хоста технически способен изменять файлы и БД. Приложение не может гарантировать неизменяемость журналов против владельца всех прав ОС. Для такого уровня защиты нужны независимое хранение и организационное разделение полномочий.

4 Сценарии угроз и меры

Обозначения У01–У12 являются локальными идентификаторами настоящего документа, а не номерами угроз банка ФСТЭК.

Код	Сценарий	Предусмотренные меры и остаточная задача
У01	Подбор или кража пароля	Хеширование паролей, серверная аутентификация, блокировка аккаунта; уникальные пароли и контроль выдачи
У02	Просмотр чужой оценки или карточки	Проверка роли и владельца на API; проверять изменения новых маршрутов
У03	Подмена эталона или оценки	Версии и аудит экспертных решений; контроль прав преподавателя
У04	Перехват входа и речи	HTTPS, WSS, SIP TLS и SRTP; доверие сертификату и проверка имени клиента
У05	Утечка ENV или ключа СА	Исключение из Git и образов; права файлов, отдельное хранение и запрет публикации логов ENV
У06	Произвольный доступ к Ollama	Сегментация, закрытый 11434; при выносе на узел добавить защищённый транспорт

Код	Сценарий	Предусмотренные меры и остаточная задача
Y07	Инструкция в документе меняет роль ИИ	Ограниченный контекст, разделение фактов и инструкций, утверждение преподавателем; остаточные ошибки модели возможны
Y08	Вредоносный файл или ресурсозатратный PDF	Ограничения загрузки, локальные парсеры и OCR; обновление библиотек и изоляция ресурсов
Y09	Исчерпание CPU, RAM или диска	Лимиты контейнеров, очереди, таймауты и мониторинг; планирование нагрузки и места
Y10	Потеря БД или записей	Ежедневные зашифрованные копии; независимая копия и проверенное восстановление
Y11	Подмена образа или модели	Фиксация версий, проверка источников и контрольных сумм; реестр поставки
Y12	Удаление журнала привилегированным лицом	Ограничение прав и резервирование; при необходимости независимый архив

5 Настройка доступа

Выдавайте персональные аккаунты. Ученикам не предоставляются роли преподавателя и администратора. После ухода пользователя блокируйте доступ, сохраняя историю в соответствии с принятой политикой.

Демонстрационные аккаунты с известными паролями нельзя оставлять доступными в рабочей ученической сети.

SIP-пароли выдаются отдельно для каждого рабочего места. Файл MicroSIP с сохранённым паролем защищают правами пользователя. Общие папки и мессенджеры не используются для передачи серверных ENV и ключей.

Подключение LDAPS подтверждает учётные данные каталога, но не выдаёт роль администратора автоматически. Администратор явно связывает учётную запись каталога с локальным профилем.

6 Защита сети и ключей

Разрешите HTTPS 3000, SIP TLS 5061 и нужный SRTP-диапазон только из учебной сети. Не публикуйте внутренние API, БД, ARI и Ollama в Интернет. Не отключайте проверку сертификатов для устранения ошибок настройки.

Перед установкой публичного СА на рабочее место сверьте отпечаток по доверенному каналу. Закрытый ключ СА хранится вне работающих контейнеров. Серверные ключи доступны только соответствующему сервису. При компрометации выполняются отзыв доверия, замена затронутых ключей и документированное обновление клиентов.

Для текущего обращения к Ollama по HTTP необходимо ограничить доступ доверенным серверным сегментом. При разнесении узлов требуется дополнительная защита этого канала.

7 Журналирование и резервирование

Приложение регистрирует действия аккаунтов, учебные события, метаданные HTTP и WebSocket. Запись аудио и журнал безопасности имеют разные назначения. Пароли, содержимое секретных заголовков и полные тела запросов не должны попадать в публичные диагностические отчёты.

Политика безопасности предусматривает хранение журналов не менее 183 дней с ротацией и архивированием. Администратор контролирует ёмкость диска и вынос архивов. Отсутствие автоматического удаления не защищает от неисправности носителя.

Ежедневные копии шифруются AES-256-GCM. Ключ хранится отдельно. Во время активной записи голоса файловая часть копии может отражать момент снимка. Для согласованной копии завершите занятия перед резервированием.

8 Действия при инциденте

1. Зафиксировать время, пользователя, карточку, сервис и вид нарушения, не включая пароль в сообщение.
2. При подозрении на компрометацию ограничить доступ затронутого аккаунта или сетевого узла.
3. Сохранить журналы и сведения о версиях до перезапуска или очистки.
4. Проверить изменения ролей, оценок, сценариев и конфигурации.
5. При необходимости заменить секреты и восстановить данные на отдельном стенде из проверенной копии.
6. Выполнить контрольный вход и учебный цикл; разрешить возврат в работу ответственным лицом.

Преподавателю сообщают о влиянии на результаты обучения. Администратор не изменяет оценки напрямую для сокрытия инцидента. Причины, принятые меры и дату восстановления заносят в журнал сопровождения.

9 Уточнение перед вводом

Владелец назначает ответственных, определяет категории данных и сроки хранения, утверждает сетевую схему, процедуры выдачи доступа, реагирования и восстановления. Модель пересматривается при подключении внешнего каталога, переносе Ollama на другой узел, изменении состава данных или предоставлении удалённого доступа.

При внедрении дополните модель сведениями о сети организации, пользователях, данных и средствах защиты.